



NATIONAL CYBER SECURITY LAW

Sairaj Patekar & Tanvesh Shinde |
24101B0081 | 24102C0066 |
Cybersecurity Law & Policy





INTRO VIT

PURPOSE

Establish a legal, regulatory & technical framework for VIT's digital ecosystem.

NECESSITY

50M+ users at risk from ransomware, data breaches, phishing & identity theft.

SCOPE

Extra-territorial reach · NCSA creation · Zero-trust mandates · Inviolable digital rights · Corporate liability





KEY DEFINITIONS



Cybercrime

Any unlawful act committed using computers, networks, or the internet — including hacking, data theft, fraud, and sabotage of digital systems.



Hacker

An individual who gains unauthorized access to computer systems or networks, exploiting vulnerabilities to steal data, disrupt services, or cause harm.



Ethical Hacker

A certified security professional authorized to probe systems for vulnerabilities using the same techniques as malicious hackers, but lawfully and with consent.



Malware

Malicious software designed to infiltrate, damage, or disable computers — including viruses, worms, trojans, spyware, and ransomware variants.





KEY DEFINITIONS



Ransomware

Malicious software that encrypts a victim's files or systems, demanding a ransom payment for restoration of access.



Phishing

A deceptive cyberattack using fraudulent emails, messages, or websites to trick users into revealing sensitive credentials.



Data Breach

An unauthorized access or disclosure of confidential, protected, or sensitive data by an internal or external threat actor.



Personal Data

Any information that identifies or can identify a natural person, including name, ID number, location, or online identifier.





🔑 Digital Signature: A cryptographic mechanism used to verify the authenticity and integrity of digital messages or documents, ensuring non-repudiation in electronic transactions.

🔒 Encryption: The process of converting readable data (plaintext) into an unreadable format (ciphertext) using algorithms, protecting information from unauthorized access or interception.

🕵️ Electronic Evidence: Any digital data stored or transmitted in binary form that may be relied upon in court, including logs, emails, files, and metadata. Identity Theft: Fraudulent acquisition and use of another person's private identifying information for financial gain or deception.

KEY DEFINITIONS





KEY DEFINITIONS



Artificial Intelligence (AI)

Machine-based systems capable of performing tasks that typically require human intelligence, including decision-making, pattern recognition, and autonomous action in cyberspace.



Cloud Computing

Delivery of computing services — servers, storage, databases, networking, and software — over the internet, subject to data sovereignty and cross-border transfer regulations.



Critical Infrastructure

Essential systems and assets — including banks, hospitals, power grids, and government networks — whose disruption would severely impact national security or public welfare.



Cyberbullying

Repeated use of digital platforms to harass, threaten, humiliate, or intimidate individuals, constituting a punishable offense under VIT's National Cybersecurity Law.





CITIZEN'S DIGITAL RIGHTS

Right to Privacy

Every citizen's personal data is protected by law. Unauthorized collection, profiling, or surveillance is strictly prohibited. Violations carry fines up to ₹50L and 3 years imprisonment.

Right to Secure Data

Citizens are entitled to AES-256 encrypted storage of their data. Organizations must implement zero-trust architecture. Non-compliance results in fines up to ₹1 crore and mandatory audits.

Right to Data Deletion

Citizens may request permanent deletion of personal data at any time. Organizations must comply within 30 days using crypto-shredding. Failure to comply incurs penalties up to ₹25L per violation.





CITIZEN'S DIGITAL RIGHTS

Right to Information

Citizens have the right to be informed about data collection, processing, and usage. Organizations must provide clear, transparent disclosures about how personal data is used and stored.

Right to Report Cybercrime

Every citizen has the right to report cybercrimes without fear of retaliation. NCSA must acknowledge reports within 24 hours and initiate investigation within 72 hours of filing.

Right to Fair Investigation

All individuals are entitled to impartial, evidence-based cyber investigations. Accused parties retain due process rights; digital evidence must follow strict chain-of-custody protocols.





Offense Severity Range

Imprisonment: 1–25 years depending on offense category. Fines range from ₹50,000 for unauthorized access to ₹50 Crore for cyber terrorism.

Penalties & Fines

12 classified offenses: Unauthorized Access, Data Theft, Identity Theft, Phishing, Ransomware, Malware, Cyberbullying, Harassment, Financial Fraud, Misinformation, Defacement, Cyber Terrorism.

● Maximum Imprisonment (years)

● Fine (₹ Lakhs)



Source: AI-generated data. Replace or verify before use.

CYBER OFFENSES





CYBER OFFENSES

Phishing

Fraudulent messages to steal credentials or financial data. Penalty: 5 years imprisonment + ₹10 Lakh fine. Includes spear phishing and whaling attacks.

Ransomware

Encrypting victim systems and demanding ransom for decryption keys. Penalty: 10 years imprisonment + ₹25 Lakh fine. Critical infrastructure attacks carry maximum sentence.

Malware Distribution

Deploying malicious software to damage, disrupt, or gain unauthorized access to systems. Penalty: 7 years imprisonment + ₹20 Lakh fine. Includes trojans, spyware, and worms.





CYBER OFFENSES

Cyberbullying

Penalty: 3 years imprisonment + ₹5 Lakh fine. Includes repeated online harassment, threatening messages, public humiliation via digital platforms, and targeted abuse intended to cause emotional distress.

Online Harassment

Penalty: 5 years imprisonment + ₹10 Lakh fine. Covers stalking, doxxing, non-consensual image sharing, and persistent digital intimidation causing fear or psychological harm to victims.

Financial Fraud

Penalty: 10 years imprisonment + ₹25 Lakh fine. Encompasses online banking fraud, UPI scams, investment fraud, credit card cloning, and digital impersonation for financial gain.





Collection & Storage

Data minimization at collection; explicit disclosure required. Storage must use AES-256 encryption with strict access controls and role-based permissions.

Sharing & Retention

Secondary data sharing requires renewed user consent. Maximum retention period: 5 years. Deletion via crypto-shredding ensures irrecoverable data removal.

Breach Notification

Organizations must report data breaches to NCSA within 72 hours of detection. Failure to notify constitutes a separate offense with independent penalties.

DATA PROTECTION FRAMEWORK





CORPORATE RESPONSIBILITIES



DPO Appointment

Every organization must appoint a certified Data Protection Officer. Non-compliance fine: ₹25 Lakhs. Ensures accountability for data governance and privacy compliance.



MFA Implementation

Multi-Factor Authentication required on all privileged accounts and public-facing portals. Non-compliance fine: ₹10 Lakhs. Prevents unauthorized access and credential theft.



Penetration Testing

Mandatory bi-annual penetration testing of all critical systems and networks. Non-compliance fine: ₹15 Lakhs. Identifies vulnerabilities before malicious actors exploit them.



Breach Disclosure

Mandatory 72-hour breach notification to NCSA and affected individuals. Non-compliance fine: ₹50 Lakhs. Enables rapid coordinated response and minimizes damage.





CORPORATE MANDATES



Security Training

Mandatory cybersecurity awareness programs for all staff. Annual drills, phishing simulations, and role-based training. Fine for non-compliance: ₹5 Lakhs.



System Isolation

Critical systems must be network-segmented and air-gapped where required. Prevents lateral movement during breaches. Fine: ₹30 Lakhs.



Audit Logs

Tamper-proof logs of all system access and data transactions must be retained for 5 years. Real-time monitoring required. Fine: ₹20 Lakhs.



Vendor Risk Management

Third-party vendors must comply with VIT cybersecurity standards. Regular audits, contractual obligations, and risk assessments mandatory. Fine: ₹15 Lakhs.



CORPORATE MANDATES

Disaster Recovery

Organizations must maintain a tested Disaster Recovery Plan (DRP) with regular drills, offsite backups, and documented RTO/RPO targets. Non-compliance fine: ₹40L.

Vulnerability Disclosure

All discovered vulnerabilities must be responsibly disclosed to NCSA within defined timelines. Bug bounty programs are mandated for critical systems. Non-compliance fine: ₹25L.



GOVT. RESPONSIBILITIES

01

Protect Critical Infrastructure

Ensure security of banks, hospitals, airports, power plants, railways, and government data centers against cyber threats and attacks.

02

Monitor Cyber Threats

Continuously surveil national cyberspace, detect emerging threats, issue early warnings, and coordinate real-time threat intelligence sharing.

03

Investigate Cybercrimes

Lead forensic investigations, maintain chain of custody, prosecute offenders, and coordinate with NCSA and law enforcement agencies.





GOVERNMENT DUTIES

International Coordination

Partner with global cybersecurity agencies and foreign governments to share threat intelligence, coordinate cross-border investigations, and align VIT's legal framework with international standards such as the Budapest Convention.



Awareness Programs

Launch nationwide digital literacy campaigns, school-level cybersecurity education, public helplines, and regular advisories to empower citizens against phishing, fraud, and online threats.





① Incident Detected → ② Internal Investigation
Log incident within 6 hours. Identify scope, affected systems, and initial threat vector. Assign incident response team immediately.

③ Report to Authority → ④ Risk Assessment
Submit mandatory report to NCSA within 72 hours. Assess risk severity, data exposure, and potential cascading impact on critical systems.

⑤ Mitigation → ⑥ Recovery → ⑦ Final Report
Isolate systems, apply patches, restore operations from verified backups. Submit comprehensive final forensic report with chain of custody.

INCIDENT REPORTING





Case Tracker Assignment

Each incident is assigned a unique case ID in the national tracker. Investigators are allocated within 6 hours of incident logging. Chain of custody documentation begins immediately upon assignment.

Forensic Imaging & Server Cloning

Bit-for-bit forensic imaging of affected systems is performed. Live server cloning preserves volatile memory and active processes. All forensic copies are hash-verified (SHA-256) to ensure integrity.

Evidence Compilation & Chain of Custody

Digital evidence is compiled with strict chain-of-custody logs. Metadata, access logs, and network captures are preserved. Final evidence package submitted within 72 hours for legal proceedings.

INVESTIGATION PROCESS





NCSA

STRUCTURE & POWERS



Director General & Leadership

Director General oversees all NCSA operations. Deputy Directors manage TIU, VIT-CERT, Forensics, Compliance Audit & Public Education Bureau.



Digital Forensics & Compliance

Digital Forensics Unit handles evidence collection, forensic imaging & chain of custody. Compliance Audit enforces corporate cybersecurity mandates.



TIU & VIT-CERT

Threat Intelligence Unit monitors active cyber threats. VIT-CERT coordinates rapid incident response and national vulnerability advisories.



NCSA Powers & Enforcement

Powers include: issuing subpoenas, imposing penalties, conducting audits, ordering platform shutdowns & operating a national cyber helpline.





NCSA POWERS

National Cyber Security Authority enforcement powers: subpoenas, penalties, audits, platform shutdown, and a 24/7 public helpline.



Compliance Audit Department

Conducts mandatory audits of all registered entities. Issues compliance certificates, levies penalties up to ₹50L for violations, and enforces corrective action orders with strict deadlines.



Public Education Bureau & Helpline

Operates the national cyber helpline for citizen reporting. Runs awareness campaigns, school programs, and digital literacy drives. Coordinates with VIT-CERT for public advisories.





AI & EMERGING TECH

Artificial Intelligence

Risk: Algorithmic bias, autonomous decision-making without accountability, and opaque AI systems. Regulation: Mandatory bias audits, explainability standards, and human oversight requirements for all AI deployments.

Deepfakes & Synthetic Media

Risk: Identity fraud, misinformation, and non-consensual synthetic content. Regulation: Mandatory digital watermarking, disclosure mandates for AI-generated content, and criminal liability for malicious deepfake creation.

Internet of Things (IoT)

Risk: Insecure connected devices enabling large-scale botnets, data leaks, and infrastructure attacks. Regulation: Mandatory IoT security certification, default password bans, and regular firmware update requirements.





EMERGING TECH LAWS

Cloud Computing

Data localization mandates require storage within VIT jurisdiction. Cross-border transfers need NCSA approval. Providers must ensure AES-256 encryption and uptime SLAs.

Digital Identity

Biometric and digital ID systems must use multi-factor verification. Identity providers bear liability for breaches. Spoofing and impersonation carry up to 7 years imprisonment.

Autonomous Systems

Developers and deployers share joint liability for harm caused by autonomous systems. Mandatory audit trails, kill-switch requirements, and algorithmic transparency reports are enforced.





CRITICAL INFRASTRUCTURE

Banks

Real-time transaction monitoring, AES-256 encryption for financial records, MFA for all banking portals, incident response within 6 hours, mandatory audit logs.

Hospitals

End-to-end encryption of patient data, air-gapped backup systems, strict role-based access controls, 72-hour breach notification, ransomware resilience protocols.

Airports

Biometric access controls for restricted zones, network segmentation for operational systems, zero-trust architecture, continuous threat monitoring, secure communication channels.





CRITICAL INFRASTRUCTURE

Railways

SCADA systems must be isolated from public networks. Mandatory intrusion detection on signaling systems. Real-time monitoring of track control networks. Encrypted communication for all operational commands.

Power Plants

Air-gapped systems required for core control units. Industrial control systems (ICS) must undergo quarterly audits. Physical and cyber perimeter security enforced. Backup power and failover protocols mandated.

Govt. Data Centers

Zero-trust architecture enforced across all access layers. Multi-factor authentication mandatory for all personnel. AES-256 encryption for data at rest and in transit. Continuous threat monitoring and 24/7 SOC operations.





Apex Retail Data Leak

Massive customer data breach exposing PII of thousands. Fine imposed: ₹45 Lakhs. Key lesson: Staging environments must be isolated from production systems with strict access controls.



Horizon Phishing Ring

Organized phishing campaign resulting in ₹1.2 Crore fraud across multiple victims. Perpetrators received 7-year sentences. Key lesson: Telecom filtering and real-time monitoring can disrupt large-scale phishing networks.



Hospital Ransomware Attack

Critical healthcare infrastructure targeted, disrupting patient care systems. Offenders sentenced to 15 years. Key lesson: Air-gapped backups and offline recovery systems are essential for critical infrastructure resilience.

CASE STUDIES





FUTURE RECOMMENDATIONS

01

AI Security (2026–2030)

Regulate AI-driven threat detection, mandate algorithmic audits, establish liability for autonomous cyber decisions, and ban weaponized AI tools.

02

Quantum Computing Readiness

Transition to post-quantum cryptography standards, mandate quantum-safe encryption for critical infrastructure, and prepare for quantum-enabled cyber threats.

03

Enhanced Privacy Protection

Strengthen data sovereignty laws, enforce privacy-by-design mandates, expand digital rights for citizens, and introduce stricter cross-border data transfer controls.





**THANK
YOU!**

